

GitHub Security Report

Repository

<https://github.com/codingforentrepreneurs/eCommerce>

Risk Summary

Risk Score: 217
Risk Level: CRITICAL
Total Vulnerabilities: 36
Errors: 9
Warnings: 25
Info: 2
Scan Duration: 11.252556524s

Summary By Type

python.django.security.django-no-csrf-token.django-no-csrf-token : 2
python.django.security.audit.avoid-mark-safe.avoid-mark-safe : 4
python.django.security.audit.unvalidated-password.unvalidated-password : 3
python.django.security.django-using-request-post-after-is-valid.django-using-request-post-after-is-valid : 1
generic.secrets.security.detected-generic-api-key.detected-generic-api-key : 1
html.security.plaintext-http-link.plaintext-http-link : 1
private-key : 3
html.security.audit.missing-integrity.missing-integrity : 8
generic.secrets.security.detected-aws-access-key-id-value.detected-aws-access-key-id-value : 1
python.django.security.audit.xss.template-blocktranslate-no-escape.template-blocktranslate-no-escape : 2
javascript.lang.security.audit.incomplete-sanitization.incomplete-sanitization : 4
generic-api-key : 3
python.django.security.audit.xss.direct-use-of-httpresponse.direct-use-of-httpresponse : 1
generic.secrets.security.detected-mailchimp-api-key.detected-mailchimp-api-key : 1
javascript.lang.security.audit.detect-non-literal-regexp.detect-non-literal-regexp : 1

Vulnerabilities

Vulnerability #1

Severity : **ERROR**
Type : generic.secrets.security.detected-aws-access-key-id-value.detected-aws-access-key-id-value
File : repos/scan-1782722830304200640/src/ecommerce/aws/conf.py
Line : 7
Description :

AWS Access Key ID Value detected. This is a sensitive credential and should not be hardcoded here. Instead, read this value from an environment variable or keep it in a separate, private file.

Vulnerability #2

Severity : ERROR

Type : generic-api-key

File : context_test.go

Line : 825

Description :

Detected a Generic API Key, potentially exposing access to various services and sensitive operations.

Vulnerability #3

Severity : ERROR

Type : private-key

File : examples/http2/testdata/server.key

Line : 1

Description :

Identified a Private Key, which may compromise cryptographic security and sensitive data encryption.

Vulnerability #4

Severity : ERROR

Type : private-key

File : fixtures/testdata/key.pem

Line : 1

Description :

Identified a Private Key, which may compromise cryptographic security and sensitive data encryption.

Vulnerability #5

Severity : ERROR

Type : private-key

File : examples/http-pusher/testdata/server.key

Line : 1

Description :

Identified a Private Key, which may compromise cryptographic security and sensitive data encryption.

Vulnerability #6

Severity : ERROR

Type : generic-api-key

File : context_test.go

Line : 438

Description :

Detected a Generic API Key, potentially exposing access to various services and sensitive operations.

Vulnerability #7

Severity : ERROR

Type : generic-api-key

File : context_test.go

Line : 430

Description :

Detected a Generic API Key, potentially exposing access to various services and sensitive operations.

Vulnerability #8

Severity : ERROR

Type : generic.secrets.security.detected-mailchimp-api-key.detected-mailchimp-api-key

File : repos/scan-1782722830304200640/src/ecommerce/settings/base.py

Line : 82

Description :

MailChimp API Key detected

Vulnerability #9

Severity : ERROR

Type : generic.secrets.security.detected-generic-api-key.detected-generic-api-key

File : repos/scan-1782722830304200640/src/ecommerce/settings/base.py

Line : 82

Description :

Generic API Key detected

Vulnerability #10

Severity : WARNING

Type : html.security.audit.missing-integrity.missing-integrity

File : repos/scan-1782722830304200640/src/templates/base/js.html

Line : 10

Description :

This tag is missing an 'integrity' subresource integrity attribute. The 'integrity' attribute allows for the browser to verify that externally hosted files (for example from a CDN) are delivered without unexpected manipulation. Without this attribute, if an attacker can modify the externally hosted resource, this could lead to XSS and other types of attacks. To prevent this, include the base64-encoded cryptographic hash of the resource (file) you're telling the browser to fetch in the 'integrity' attribute for all externally hosted files.

Vulnerability #11

Severity : WARNING

Type : html.security.plaintext-http-link.plaintext-http-link

File : repos/scan-1782722830304200640/src/templates/bootstrap/example.html

Line : 39

Description :

This link points to a plaintext HTTP URL. Prefer an encrypted HTTPS URL if possible.

Vulnerability #12

Severity : WARNING

Type : python.django.security.audit.xss.direct-use-of-httpresponse.direct-use-of-httpresponse

File : repos/scan-1782722830304200640/src/billing/views.py

Line : 40

Description :

Detected data rendered directly to the end user via 'HttpResponse' or a similar object. This bypasses Django's built-in cross-site scripting (XSS) defenses and could result in an XSS vulnerability. Use Django's template engine to safely render HTML.

Vulnerability #13

Severity : WARNING

Type : python.django.security.django-no-csrf-token.django-no-csrf-token

File : repos/scan-1782722830304200640/src/addresses/templates/addresses/prev_addresses.ht

ml

Line : 2

Description :

Manually-created forms in django templates should specify a csrf_token to prevent CSRF attacks.

Vulnerability #14

Severity : WARNING

Type : python.django.security.audit.avoid-mark-safe.avoid-mark-safe

File : repos/scan-1782722830304200640/src/accounts/views.py

Line : 54

Description :

'mark_safe()' is used to mark a string as "safe" for HTML output. This disables escaping and could therefore subject the content to XSS attacks. Use 'django.utils.html.format_html()' to build HTML for rendering instead.

Vulnerability #15

Severity : WARNING

Type : python.django.security.audit.unvalidated-password.unvalidated-password

File : repos/scan-1782722830304200640/src/accounts/models.py

Line : 30

Description :

The password on 'user_obj' is being set without validating the password. Call django.contrib.auth.password_validation.validate_password() with validation functions before setting the password. See <https://docs.djangoproject.com/en/3.0/topics/auth/passwords/> for more information.

Vulnerability #16

Severity : WARNING

Type : html.security.audit.missing-integrity.missing-integrity

File : repos/scan-1782722830304200640/src/templates/base/css.html

Line : 6

Description :

This tag is missing an 'integrity' subresource integrity attribute. The 'integrity' attribute allows for the browser to verify that externally hosted files (for example from a CDN) are delivered without unexpected manipulation. Without this attribute, if an attacker can modify the externally hosted resource, this could lead to XSS and other types of attacks. To prevent this, include the base64-encoded cryptographic hash of the resource (file)

youâ€™re telling the browser to fetch in the 'integrity' attribute for all externally hosted files.

Vulnerability #17

Severity : WARNING

Type : html.security.audit.missing-integrity.missing-integrity

File : repos/scan-1782722830304200640/src/templates/base/css.html

Line : 9

Description :

This tag is missing an 'integrity' subresource integrity attribute. The 'integrity' attribute allows for the browser to verify that externally hosted files (for example from a CDN) are delivered without unexpected manipulation. Without this attribute, if an attacker can modify the externally hosted resource, this could lead to XSS and other types of attacks. To prevent this, include the base64-encoded cryptographic hash of the resource (file) youâ€™re telling the browser to fetch in the 'integrity' attribute for all externally hosted files.

Vulnerability #18

Severity : WARNING

Type : html.security.audit.missing-integrity.missing-integrity

File : repos/scan-1782722830304200640/src/templates/base/js.html

Line : 5

Description :

This tag is missing an 'integrity' subresource integrity attribute. The 'integrity' attribute allows for the browser to verify that externally hosted files (for example from a CDN) are delivered without unexpected manipulation. Without this attribute, if an attacker can modify the externally hosted resource, this could lead to XSS and other types of attacks. To prevent this, include the base64-encoded cryptographic hash of the resource (file) youâ€™re telling the browser to fetch in the 'integrity' attribute for all externally hosted files.

Vulnerability #19

Severity : WARNING

Type : python.django.security.django-no-csrf-token.django-no-csrf-token

File : repos/scan-1782722830304200640/fasttracktojquery/index.html

Line : 34

Description :

Manually-created forms in django templates should specify a csrf_token to prevent CSRF attacks.

Vulnerability #20

Severity : WARNING

Type : html.security.audit.missing-integrity.missing-integrity

File : repos/scan-1782722830304200640/src/templates/base/js.html

Line : 14

Description :

This tag is missing an 'integrity' subresource integrity attribute. The 'integrity' attribute allows for the browser to verify that externally hosted files (for example from a CDN) are delivered without unexpected manipulation. Without this attribute, if an attacker can modify the externally hosted resource, this could lead to XSS and other types of attacks. To prevent this, include the base64-encoded cryptographic hash of the resource (file) you're telling the browser to fetch in the 'integrity' attribute for all externally hosted files.

Vulnerability #21

Severity : WARNING

Type : html.security.audit.missing-integrity.missing-integrity

File : repos/scan-1782722830304200640/src/templates/base/js.html

Line : 17

Description :

This tag is missing an 'integrity' subresource integrity attribute. The 'integrity' attribute allows for the browser to verify that externally hosted files (for example from a CDN) are delivered without unexpected manipulation. Without this attribute, if an attacker can modify the externally hosted resource, this could lead to XSS and other types of attacks. To prevent this, include the base64-encoded cryptographic hash of the resource (file) you're telling the browser to fetch in the 'integrity' attribute for all externally hosted files.

Vulnerability #22

Severity : WARNING

Type : html.security.audit.missing-integrity.missing-integrity

File : repos/scan-1782722830304200640/src/templates/base/js.html

Line : 22

Description :

This tag is missing an 'integrity' subresource integrity attribute. The 'integrity' attribute allows for the browser to verify that externally hosted files (for example from a CDN) are delivered without unexpected manipulation. Without this attribute, if an attacker can modify the externally hosted resource, this could lead to XSS and other types of attacks. To prevent this, include the base64-encoded cryptographic hash of the resource (file) you're telling the browser to fetch in the 'integrity' attribute for all externally hosted files.

Vulnerability #23

Severity : WARNING

Type : python.django.security.django-using-request-post-after-is-valid.django-using-request-post-after-is-valid

File : repos/scan-1782722830304200640/src/addresses/views.py

Line : 69

Description :

Use `form.cleaned_data[]` instead of `request.POST[]` after `form.is_valid()` has been executed to only access sanitized data

Vulnerability #24

Severity : WARNING

Type : html.security.audit.missing-integrity.missing-integrity

File : repos/scan-1782722830304200640/fasttracktojquery/index.html

Line : 105

Description :

This tag is missing an 'integrity' subresource integrity attribute. The 'integrity' attribute allows for the browser to verify that externally hosted files (for example from a CDN) are delivered without unexpected manipulation. Without this attribute, if an attacker can modify the externally hosted resource, this could lead to XSS and other types of attacks. To prevent this, include the base64-encoded cryptographic hash of the resource (file) you're telling the browser to fetch in the 'integrity' attribute for all externally hosted files.

Vulnerability #25

Severity : WARNING

Type : python.django.security.audit.avoid-mark-safe.avoid-mark-safe

File : repos/scan-1782722830304200640/src/accounts/forms.py

Line : 22

Description :

'`mark_safe()`' is used to mark a string as "safe" for HTML output. This disables escaping and could therefore subject the content to XSS attacks. Use '`django.utils.html.format_html()`' to build HTML for rendering instead.

Vulnerability #26

Severity : WARNING

Type : javascript.lang.security.audit.incomplete-sanitization.incomplete-sanitization

File : repos/scan-1782722830304200640/static_cdn/static_root/admin/js/admin/DateTimeShortcuts.js

Line : 410

Description :

`format.replace` method will only replace the first occurrence when used with a string argument (`\r`). If this method is used for escaping of dangerous data then there is a possibility for a bypass. Try to use sanitization library instead or use a Regex with a global flag.

Vulnerability #27

Severity : WARNING

Type : javascript.lang.security.audit.incomplete-sanitization.incomplete-sanitization

File : repos/scan-1782722830304200640/static_cdn/static_root/admin/js/admin/DateTimeShortcuts.js

Line : 411

Description :

`format.replace` method will only replace the first occurrence when used with a string argument (`\n`). If this method is used for escaping of dangerous data then there is a possibility for a bypass. Try to use sanitization library instead or use a Regex with a global flag.

Vulnerability #28

Severity : WARNING

Type : javascript.lang.security.audit.incomplete-sanitization.incomplete-sanitization

File : repos/scan-1782722830304200640/static_cdn/static_root/admin/js/admin/DateTimeShortcuts.js

Line : 412

Description :

`format.replace` method will only replace the first occurrence when used with a string argument (`\t`). If this method is used for escaping of dangerous data then there is a possibility for a bypass. Try to use sanitization library instead or use a Regex with a global flag.

Vulnerability #29

Severity : WARNING

Type : javascript.lang.security.audit.incomplete-sanitization.incomplete-sanitization

File : repos/scan-1782722830304200640/static_cdn/static_root/admin/js/admin/DateTimeShortcuts.js

Line : 413

Description :

`format.replace` method will only replace the first occurrence when used with a string argument (``). If this method is used for escaping of dangerous data then there is a possibility for a bypass. Try to use sanitization library instead or use a Regex with a global flag.

Vulnerability #30

Severity : WARNING

Type : javascript.lang.security.audit.detect-non-literal-regexp.detect-non-literal-regexp

File : repos/scan-1782722830304200640/static_cdn/static_root/admin/js/inlines.js

Line : 25

Description :

RegExp() called with a `prefix` function argument, this might allow an attacker to cause a Regular Expression Denial-of-Service (ReDoS) within your application as RegExp blocks the main thread. For this reason, it is recommended to use hardcoded regexes instead. If your regex is run on user-controlled input, consider performing input validation or use a regex checking/sanitization library such as <https://www.npmjs.com/package/recheck> to verify that the regex does not appear vulnerable to ReDoS.

Vulnerability #31

Severity : WARNING

Type : python.django.security.audit.unvalidated-password.unvalidated-password

File : repos/scan-1782722830304200640/src/accounts/forms.py

Line : 194

Description :

The password on 'user' is being set without validating the password. Call `django.contrib.auth.password_validation.validate_password()` with validation functions before setting the password. See <https://docs.djangoproject.com/en/3.0/topics/auth/passwords/> for more information.

Vulnerability #32

Severity : WARNING

Type : python.django.security.audit.avoid-mark-safe.avoid-mark-safe

File : repos/scan-1782722830304200640/src/accounts/forms.py

Line : 136

Description :

'mark_safe()' is used to mark a string as "safe" for HTML output. This disables escaping and could therefore subject the content to XSS attacks. Use 'django.utils.html.format_html()' to build HTML for rendering instead.

Vulnerability #33

Severity : WARNING

Type : python.django.security.audit.avoid-mark-safe.avoid-mark-safe

File : repos/scan-1782722830304200640/src/accounts/forms.py

Line : 132

Description :

'mark_safe()' is used to mark a string as "safe" for HTML output. This disables escaping and could therefore subject the content to XSS attacks. Use 'django.utils.html.format_html()' to build HTML for rendering instead.

Vulnerability #34

Severity : WARNING

Type : python.django.security.audit.unvalidated-password.unvalidated-password

File : repos/scan-1782722830304200640/src/accounts/forms.py

Line : 47

Description :

The password on 'user' is being set without validating the password. Call `django.contrib.auth.password_validation.validate_password()` with validation functions before setting the password. See <https://docs.djangoproject.com/en/3.0/topics/auth/passwords/> for more information.

Vulnerability #35

Severity : INFO

Type : python.django.security.audit.xss.template-blocktranslate-no-escape.template-blocktranslate-no-escape

File : repos/scan-1782722830304200640/src/templates/registration/password_reset_email.txt

Line : 2

Description :

Translated strings will not be escaped when rendered in a template. This leads to a vulnerability where translators could include malicious script tags in their translations. Consider using ``force_escape`` to explicitly escape a translated text.

Vulnerability #36

Severity : INFO

Type : python.django.security.audit.xss.template-blocktranslate-no-escape.template-blocktranslate-no-escape

File : repos/scan-1782722830304200640/src/templates/registration/password_reset_email.html

Line : 2

Description :

Translated strings will not be escaped when rendered in a template. This leads to a vulnerability where translators could include malicious script tags in their translations. Consider using `force\_escape` to explicitly escape a translated text.

Severity	Type	File	Line	Description
ERROR	generic.secrets.security.detected-api-key	repos/scan-1782722830304200640/src/secret_key.py	1	API Access Key ID Value detected. This is
ERROR	generic-api-key	context_test.go	825	Detected a Generic API Key, potentially exp
ERROR	private-key	examples/http2/testdata/server.key	1	Identified a Private Key, which may compro
ERROR	private-key	fixtures/testdata/key.pem	1	Identified a Private Key, which may compro
ERROR	private-key	examples/http-pusher/testdata/server.key	1	Identified a Private Key, which may compro
ERROR	generic-api-key	context_test.go	438	Detected a Generic API Key, potentially exp
ERROR	generic-api-key	context_test.go	430	Detected a Generic API Key, potentially exp
ERROR	generic.secrets.security.detected-mailchimp-api-key	repos/scan-1782722830304200640/src/ecommerce/settings/mailchimp.py	52	MailChimp API Key detected
ERROR	generic.secrets.security.detected-generics-api-key	repos/scan-1782722830304200640/src/ecommerce/settings/descrip.py	52	Generic API Key detected
WARNING	html.security.audit.missing-integrity	repos/scan-1782722830304200640/src/templates/base/js.html	1	This tag is missing an 'integrity' subresource
WARNING	html.security.plaintext-http-link.plaintext-link	repos/scan-1782722830304200640/src/templates/bootstrap/example.html	1	Example points to a plaintext HTTP URL. Pl
WARNING	python.django.security.audit.xss.direct-to-end	repos/scan-1782722830304200640/src/building_blocks.py	40	Detected data rendered directly to the end
WARNING	python.django.security.django-no-escape	repos/scan-1782722830304200640/src/addresses/templates/addresses.html	2	Manually-escaped addresses in templates
WARNING	python.django.security.audit.avoid-mark_safe	repos/scan-1782722830304200640/src/accounts/views.py	54	'mark_safe()' is used to mark a string as "sa
WARNING	python.django.security.audit.invalid-password	repos/scan-1782722830304200640/src/accounts/models.py	10	The password on 'user_obj' is being set with
WARNING	html.security.audit.missing-integrity	repos/scan-1782722830304200640/src/templates/base/css.html	1	This tag is missing an 'integrity' subresource
WARNING	html.security.audit.missing-integrity	repos/scan-1782722830304200640/src/templates/base/css.html	1	This tag is missing an 'integrity' subresource
WARNING	html.security.audit.missing-integrity	repos/scan-1782722830304200640/src/templates/base/js.html	1	This tag is missing an 'integrity' subresource
WARNING	python.django.security.django-no-escape	repos/scan-1782722830304200640/fasttracktoquery/index.html	74	Manually-created forms in django templates
WARNING	html.security.audit.missing-integrity	repos/scan-1782722830304200640/src/templates/base/js.html	1	This tag is missing an 'integrity' subresource
WARNING	html.security.audit.missing-integrity	repos/scan-1782722830304200640/src/templates/base/js.html	1	This tag is missing an 'integrity' subresource

WARNING	html.security.audit.missing-integrity	https://cdn.jsdelivr.net/gh/1782722830304200640/src/templates/base/js.html	1782722830304200640	base/js.html	This tag is missing an 'integrity' subresource
WARNING	python.django.security.django-using-requests-proxies	https://cdn.jsdelivr.net/gh/1782722830304200640/src/accounts/for149.py	1782722830304200640	src/accounts/for149.py	is_valid(cleaned_data[]) instead of request
WARNING	html.security.audit.missing-integrity	https://cdn.jsdelivr.net/gh/1782722830304200640/fasttracktoquery105/index.html	1782722830304200640	fasttracktoquery105/index.html	This tag is missing an 'integrity' subresource
WARNING	python.django.security.audit.avoid-marshal	https://cdn.jsdelivr.net/gh/1782722830304200640/src/accounts/for22.py	1782722830304200640	src/accounts/for22.py	'mark_safe()' is used to mark a string as "sa
WARNING	javascript.lang.security.audit.incomplete-replace	https://cdn.jsdelivr.net/gh/1782722830304200640/static_cdn/static1100/adform/ja/replac/Date/Time/Shift/multi.js	1782722830304200640	static_cdn/static1100/adform/ja/replac/Date/Time/Shift/multi.js	replace the
WARNING	javascript.lang.security.audit.incomplete-replace	https://cdn.jsdelivr.net/gh/1782722830304200640/static_cdn/static1100/adform/ja/replac/Date/Time/Shift/multi.js	1782722830304200640	static_cdn/static1100/adform/ja/replac/Date/Time/Shift/multi.js	replace the
WARNING	javascript.lang.security.audit.incomplete-replace	https://cdn.jsdelivr.net/gh/1782722830304200640/static_cdn/static1100/adform/ja/replac/Date/Time/Shift/multi.js	1782722830304200640	static_cdn/static1100/adform/ja/replac/Date/Time/Shift/multi.js	replace the
WARNING	javascript.lang.security.audit.incomplete-replace	https://cdn.jsdelivr.net/gh/1782722830304200640/static_cdn/static1100/adform/ja/replac/Date/Time/Shift/multi.js	1782722830304200640	static_cdn/static1100/adform/ja/replac/Date/Time/Shift/multi.js	replace the
WARNING	javascript.lang.security.audit.detect-replace	https://cdn.jsdelivr.net/gh/1782722830304200640/static_cdn/static2500/adform/ja/replac/Date/Time/Shift/multi.js	1782722830304200640	static_cdn/static2500/adform/ja/replac/Date/Time/Shift/multi.js	with a `prefix` function argu
WARNING	python.django.security.audit.invalid-password	https://cdn.jsdelivr.net/gh/1782722830304200640/src/accounts/for194.py	1782722830304200640	src/accounts/for194.py	The password on 'user' is being set without
WARNING	python.django.security.audit.avoid-marshal	https://cdn.jsdelivr.net/gh/1782722830304200640/src/accounts/for136.py	1782722830304200640	src/accounts/for136.py	'mark_safe()' is used to mark a string as "sa
WARNING	python.django.security.audit.avoid-marshal	https://cdn.jsdelivr.net/gh/1782722830304200640/src/accounts/for132.py	1782722830304200640	src/accounts/for132.py	'mark_safe()' is used to mark a string as "sa
WARNING	python.django.security.audit.invalid-password	https://cdn.jsdelivr.net/gh/1782722830304200640/src/accounts/for47.py	1782722830304200640	src/accounts/for47.py	The password on 'user' is being set without
INFO	python.django.security.audit.xss.templates	https://cdn.jsdelivr.net/gh/1782722830304200640/src/templates/signtrials/5/unsaved_strings_v1.html	1782722830304200640	src/templates/signtrials/5/unsaved_strings_v1.html	if unsaved strings_v1 had the
INFO	python.django.security.audit.xss.templates	https://cdn.jsdelivr.net/gh/1782722830304200640/src/templates/signtrials/5/unsaved_strings_v1.html	1782722830304200640	src/templates/signtrials/5/unsaved_strings_v1.html	if unsaved strings_v1 had the